

mywebapp Security and Reliability Roadmap

Contents

1. Document purpose.....	3
2. Baseline	4
3. Done — no longer on the list.....	5
4. Urgent — do before the next deploy	7
4.1. Item 1 — Access-token revocation	7
4.2. Item 2 — Deploy to Fly with the v0.8.4 configuration	7
5. High — do before real users	9
5.1. Item 3 — Account lockout.....	9
5.2. Item 4 — Audit log	9
5.3. Item 5 — Escape wildcards in <code>SearchUsers</code>	10
5.4. Item 6 — <code>pg_trgm</code> index on the searched columns	10
6. Medium — do when you have a quiet week	11
6.1. Item 7 — Nonce-based CSP.....	11
6.2. Item 8 — CSRF token bound to the session	11
6.3. Item 9 — Configurable Argon2id parameters	12
6.4. Item 10 — Session cap per user	12
6.5. Item 11 — Structured audit of the boot sequence	12
7. Low — polish	14
7.1. Item 12 — Pre-commit hook to prevent secret commits.....	14
7.2. Item 13 — Log the resolved age key fingerprint at boot.....	14
7.3. Item 14 — <code>DATABASE_URL</code> support in <code>db.LoadConfig</code>	14

7.4. Item 15 — Redact sensitive fields in <code>/admin/health/detail</code>	15
7.5. Item 16 — Validate the inbound <code>X-Request-ID</code>	15
7.6. Item 17 — Benchmark the Argon2id parameters on Fly	16
8. Summary	17
9. Suggested schedule	18
10. Changes since the previous roadmap	19

patrick toca v0.8.4, October 10th, 2026

Creation Date: September 6th, 2026

Author: patrick toca

Email: pmjtoca@gmail.com

1. Document purpose

This document lists the security and reliability work that remains for **mywebapp**, ordered by when each item should be done. It is a snapshot: the state of the roadmap on 2026-10-10, after the v0.8.4 release.

Two things to understand about how the list is written:

- Items are grouped by **when** they should be done, not by **what** they are. An authentication change and a database change can be in the same group if they are urgent together.
- Every item names where the change lives, why it matters, and roughly how long it takes. The estimate is a range for one competent Go engineer working alone; it includes tests.

The list is intentionally conservative. Most items are hours, not days, and the ones that are days are the ones worth doing carefully.

2. Baseline

State of the project as of the last green `make test` before this document was written:

Check	Result
<code>make lint</code>	Clean. Three <code>QF1008</code> selectors were simplified during v0.8.4.
<code>make test</code>	Every test passes. The full suite runs in roughly two minutes on an
idle development machine.	Credentials loader
Decrypts <code>secrets/secrets.enc.yaml</code> at boot, exports six secrets.	Verified by <code>count=6</code> in the boot log.
Password hashing	Argon2id. 64 MiB memory, 3 iterations, 2 threads. 90–160 ms per
hash on the development machine.	Trusted proxies
Loaded from <code>TRUSTED_PROXIES</code> . Default is empty (trust nothing).	HSTS and CSP
<code>LoadSecurityHeadersConfig</code> refuses to return a config with HSTS	off or a CSP in report-only mode when <code>APP_ENV</code> is production or
staging. Development tolerates both.	Application boot
Serves HTTP on port 8080. The home page renders with the R2 welcome	image when the R2 credentials are present.
Development environment	Shell startup is fast. GoLand no longer competes for CPU after
excluding <code>bin/</code> , <code>logs/</code> , <code>node_modules/</code> , and <code>coverage.*</code> from	the indexer.

3. Done — no longer on the list

These items were on earlier versions of this document. They are complete and are kept here only as a record of what has changed.

#	Item
1	Fail-closed JWT and CSRF secrets. 12 passing tests across <code>internal/auth</code> and <code>internal/middleware</code> . A missing or short secret aborts the boot in production and staging.
2	DeleteUser revokes sessions in the same transaction. <code>TestUserService_DeleteUser_RevokesSessions</code> and <code>TestUserService_DeleteUser_RollsBackOnRevokeFailure</code> .
3	UpdateUserRole revokes sessions in the same transaction. <code>TestUserService_UpdateUserRole_RevokesSessions</code> and <code>TestUserService_UpdateUserRole_RollsBackOnRevokeFailure</code> .
4	Global request body limit. Four tests in <code>internal/middleware</code> .
5	SOPS + age + Fly Secrets credentials migration. The boot log shows <code>credentials loaded count=6</code> . Every database-dependent test runs against a real database.
6	Test isolation. Each test owns its user. No cross-test failures.
7	Argon2id password hashing. Nine tests. Parameters land in the OWASP performance envelope for interactive login.
8	Makefile SOPS-aware database targets. The <code>load-secrets</code> target decrypts once per invocation and caches the values in <code>.make-secrets.env</code> at mode 0600.
9	Seed program loads its own credentials. <code>scripts/seed.go</code> calls <code>credentials.Load()</code> before opening the pool and runs standalone.
10	Diagram output routes to docs/images/. Four targets: <code>diagrams</code> , <code>diagrams-check</code> , <code>diagrams-list</code> , <code>diagrams-force</code> .
11	.gitignore names every plaintext form explicitly. <code>git check-ignore</code> reports exactly the files that should be ignored.
12	Narrow trusted proxies. <code>LoadTrustedProxies</code> reads a comma-separated CIDR list from <code>TRUSTED_PROXIES</code> . Empty default. Ten tests.

#	Item
13	Secure defaults for HSTS and CSP. <code>LoadSecurityHeadersConfig</code> returns an error in production and staging when HSTS is off or CSP is report-only. Eight new tests.
14	Three QF1008 lint fixes. Simplified redundant embedded-field selectors in <code>internal/auth/jwt.go</code> and <code>internal/middleware/gzip.go</code> .

4. Urgent — do before the next deploy

These are the items that would let someone do something they should not be able to do, or that would let a single bad day become a bad week. They are small, and they belong in the same PR as the deployment configuration if you can still fit them.

4.1. Item 1 — Access-token revocation

Where	<code>internal/web/auth_middleware.go</code> , <code>internal/auth/jwt.go</code>
Why	The access token is valid for its full TTL (15 minutes by default) even after a role change, a deactivation, or a deletion. The refresh path reloads the user and fails, but the access path does not. A demoted admin keeps admin access for up to 15 minutes.
How (cheap)	Shorten <code>JWT_ACCESS_TTL</code> to 2 minutes and rely on silent refresh. The window shrinks to 2 minutes. The cost is more frequent refreshes, which is fine at the current scale.
How (full)	Add a <code>jti</code> claim to access tokens and have <code>AuthMiddleware</code> check the session table on every request. One indexed lookup per request. Closes the window entirely.
Estimate	2 hours for the cheap version, 4–6 hours for the full version.

Recommendation: the cheap version for now. The full version is justified when the user base is large enough that a two-minute window matters.

4.2. Item 2 — Deploy to Fly with the v0.8.4 configuration

Where	<code>fly.toml</code>
Why	The fail-closed checks added in v0.8.4 will refuse to start in production if <code>HSTS_MAX_AGE</code> is 0 or <code>CSP_REPORT_ONLY</code> is true. <code>fly.toml</code> must set the production values, and <code>TRUSTED_PROXIES</code> must be set to <code>fdaa::/16</code> so the rate limiter keys on the real client address rather than on the load balancer.

Where	<code>fly.toml</code>
How	Confirm the <code>[env]</code> block in <code>fly.toml</code> contains: <pre>* APP_ENV = "production" * HSTS_MAX_AGE = "31536000" * CSP_REPORT_ONLY = "false" * COOKIE_SECURE = "true" * TRUSTED_PROXIES = "fd::/16"</pre>
Estimate	15 minutes to verify, then a deploy and a read of the boot log.

After the deploy, `fly logs` should contain:

```
INFO trusted proxies configured cidrs=[fd::/16]
INFO security headers configuration hsts_max_age=31536000 hsts_include_subdomains=true hsts_preload=false csp_report_only=false
```

If either line is missing or shows different values, the configuration did not reach the process and the boot may have failed. The log names the reason.

5. High — do before real users

These items do not let an attacker in today, but they would embarrass you or fail an audit once there are users you do not personally know.

5.1. Item 3 — Account logout

Where	New <code>internal/service/login_attempts.go</code> and a small table.
Why	The login endpoint is rate-limited per IP. A botnet spread across many IPs can attack one account without triggering the limit. There is no per-account counter and no logout.
How	A <code>login_attempts</code> table with <code>email</code> , <code>count</code> , and <code>last_attempt_at</code> . Increment on failed login, clear on success. Refuse further attempts for a cooldown period after a threshold (say 10 failures, 15-minute cooldown). Log every logout at <code>warn</code> level so it is visible in <code>fly logs</code> .
Estimate	1 day, including the migration, the service, the tests, and the wiring into <code>AuthHandler.Login</code> .

5.2. Item 4 — Audit log

Where	New table <code>audit_log</code> , new package <code>internal/audit</code> , call sites in <code>UserService.UpdateUserRole</code> , <code>UserService.DeleteUser</code> , <code>UserService.UpdateUser</code> (on activation change), and <code>AuthHandler.Login</code> (on failure).
Why	There is no record of who changed whose role, who deleted whom, who failed to log in. In an incident, the HTTP access log names the request but not the actor or the target. Regulators, lawyers, and your future self will ask.
How	A table with <code>at</code> , <code>actor_id</code> , <code>action</code> , <code>target_id</code> , and <code>detail</code> (JSONB). A writer function that takes the request context so the actor and the request ID come along. Four call sites. A read-only view under <code>/admin/audit</code> for the admin to see recent entries.
Estimate	1 day, including the migration, the writer, the four call sites, the view, and the tests.

5.3. Item 5 — Escape wildcards in SearchUsers

Where	<code>internal/service/user_service.go</code> , <code>SearchUsers</code>
Why	The SQL is parameterised, so there is no injection. But <code>%</code> and <code>'</code> in the user-supplied search string are treated as wildcards by <code>ILIKE</code> . A search for <code>%</code> matches every row; a search for <code>'</code> matches any single character. This is a usability and performance problem rather than a security one.
How	Escape <code>%</code> , <code>_</code> , and <code>\</code> in the Go layer before passing the string to the query. Change the SQL to use <code>ESCAPE '\'</code> .
Estimate	1 hour, including a test.

5.4. Item 6 — `pg_trgm` index on the searched columns

Where	A new migration.
Why	<code>SearchUsers</code> does <code>ILIKE '%term%'</code> on <code>username</code> , <code>email</code> , and <code>full_name</code> . Without a trigram index, each search is a sequential scan. At a few hundred users this is invisible; at ten thousand it is the slowest query in the application.
How	<pre>CREATE EXTENSION IF NOT EXISTS pg_trgm; and CREATE INDEX ... USING gin (username gin_trgm_ops)</pre> on each of the three columns. The extension is available in Fly Postgres by default.
Estimate	1 hour.

6. Medium — do when you have a quiet week

These items make the system better in ways that will not show up as failures. They are worth doing, but nothing breaks if they wait.

6.1. Item 7 — Nonce-based CSP

Where	<code>internal/middleware/security_headers.go</code> , every template.
Why	The current CSP allows <code>'unsafe-inline'</code> and <code>'unsafe-eval'</code> in <code>script-src</code> . Both are needed because HTMX's <code>hx-on</code> attributes and the inline <code><script></code> blocks in the templates are not compatible with a stricter policy. The consequence is that any XSS that lands in a template is unrestricted.
How	Generate a nonce per request, inject it into every <code><script></code> tag, and drop <code>'unsafe-inline'</code> . HTMX's <code>hx-on</code> uses <code>new Function</code> , so <code>'unsafe-eval'</code> cannot be dropped without replacing <code>hx-on</code> with external event listeners. That is a larger change and can be done as a follow-up.
Estimate	1 day for the nonce plumbing, half a day for the template audit, half a day for the <code>hx-on</code> replacement if you decide to do it.

6.2. Item 8 — CSRF token bound to the session

Where	<code>internal/middleware/csrf.go</code> , <code>AuthHandler.issueTokens</code>
Why	The CSRF token is signed by the server, so it proves the token was issued by this server. It does not prove it was issued to this user . A subdomain XSS, a cookie-tossing attack, or a shared browser profile can move a valid CSRF token from one session to another.
How	Include the refresh token's <code>jti</code> (or the user ID) in the CSRF token's HMAC input. On validation, look up the session and confirm the token was issued for it. This turns the double-submit cookie into a synchronizer token.
Estimate	4 hours, including the schema change to record which session issued the token.

6.3. Item 9 — Configurable Argon2id parameters

Where	<code>internal/auth/password.go</code>
Why	The parameters (64 MiB, 3 iterations, 2 threads) are compile-time constants. On a slower CPU — Fly’s <code>shared-cpu-1x</code> , for example — the hash may take longer than the target 100–200 ms. Making the memory and iteration counts configurable via environment variables, with a default that matches the current values, allows per-environment tuning without a code change.
How	Read <code>ARGON2_MEMORY_KIB</code> and <code>ARGON2_ITERATIONS</code> from the environment, defaulting to the current constants. <code>HashPassword</code> uses them; <code>NeedsRehash</code> compares the stored parameters to the current ones. The <code>NeedsRehash</code> path already exists and works.
Estimate	2 hours, including tests for the environment parsing and the rehash-detection behaviour under changed parameters.

6.4. Item 10 — Session cap per user

Where	<code>internal/service/session_service.go</code>
Why	A user can accumulate unlimited session rows. Each login creates one. A long-lived account with a bot that logs in repeatedly fills the table. <code>RevokeAllUserSessions</code> mitigates on role change, but that is not a general solution.
How	Before creating a new session, count the active sessions for the user. If the count exceeds a cap (say 10), revoke the oldest. One query, one transaction.
Estimate	2 hours.

6.5. Item 11 — Structured audit of the boot sequence

Where	<code>cmd/api/main.go</code>
Why	When a boot fails, the log line names the failure but not the state that caused it. A boot log that records the resolved <code>SOPS_PATH</code> , the environment, the pool configuration, and the JWT and CSRF TTLs makes every "why did it fail on Fly but work locally" question answerable from a single <code>fly logs</code> capture.
How	A <code>slog.Info</code> line after each major step, with the values that step resolved. Most of this is already in the log; the gap is the credentials path and the pool configuration.
Estimate	1 hour.

7. Low — polish

These items improve the project but are not on any critical path.

7.1. Item 12 — Pre-commit hook to prevent secret commits

Where	<code>.pre-commit-config.yaml</code> or a shell script at <code>.git/hooks/pre-commit</code> .
Why	The <code>.env</code> incident is what surfaced the whole secrets conversation. A hook that scans staged files for <code>SECRET=</code> , <code>PASSWORD=</code> , <code>API_KEY=</code> patterns, and for the age private key format (<code>AGE-SECRET-KEY-1</code>), would have caught it at the commit.
Estimate	1 hour.

7.2. Item 13 — Log the resolved age key fingerprint at boot

Where	<code>internal/credentials/credentials.go</code>
Why	When a boot fails with "no age key available", it is useful to know whether the key file is missing, the environment variable is empty, or the key is present but for the wrong recipient. A log line with the first 8 bytes of a hash of the public key makes this a one-line diagnosis.
How	After <code>ensureAgeKey</code> , derive the public key from the loaded key, hash it, and log the first 8 bytes. The public key is not sensitive; the hash is a stable identifier.
Estimate	1 hour.

7.3. Item 14 — `DATABASE_URL` support in `db.LoadConfig`

Where	<code>pkg/db/config.go</code>
Why	<code>fly postgres attach</code> sets <code>DATABASE_URL</code> on the application and sets the individual <code>DB_*</code> variables only if you ask it to. Reading <code>DATABASE_URL</code> when present, and falling back to the individual variables, makes the Fly attach workflow seamless. It also makes the application portable to any platform that passes a <code>DATABASE_URL</code> (Heroku, Render, Railway, most Docker Compose setups).
How	In <code>LoadConfig</code> , if <code>DATABASE_URL</code> is set, parse it with <code>pgx.ParseConfig</code> and populate the fields. Otherwise use the existing <code>DB_*</code> variables. Ten lines.
Estimate	2 hours.

7.4. Item 15 — Redact sensitive fields in `/admin/health/detail`

Where	<code>internal/web/health_handler.go</code>
Why	The detail endpoint returns <code>cfg.ConnConfig.Host</code> and <code>cfg.ConnConfig.Database</code> . Admin-only, so acceptable, but on a shared host the database name can be sensitive.
How	Replace the host and database with stable hashes, or omit them.
Estimate	30 minutes.

7.5. Item 16 — Validate the inbound `X-Request-ID`

Where	<code>internal/middleware/requestid.go</code>
Why	The middleware echoes the inbound <code>X-Request-ID</code> header verbatim. An attacker can inject control characters or an over-long value. Go's <code>http.Header.Set</code> refuses values with <code>\n</code> , so the header is safe, but the value is also written into logs. Some log handlers do not escape.
How	Validate the inbound ID against <code>^[A-Za-z0-9_-]{1,64}\$</code> . If it does not match, generate a new one.
Estimate	30 minutes.

7.6. Item 17 — Benchmark the Argon2id parameters on Fly

Where	A one-off measurement, not a code change.
Why	The parameters were tuned on the development machine. Fly's <code>shared-cpu-1x</code> is slower. If the hash takes more than 500 ms, the login feels slow and the CPU is spent on authentication.
How	<code>fly ssh console</code> into the application, then: <pre>[source,bash] ---- time curl -sS -X POST http://localhost:8080/api/v1/auth/token \ -H 'Content-Type: application/json' \ -d '{"email":"alice@example.com","password":"password123"}' > /dev/null ----</pre> Run it three times and take the median. If the round-trip is over 1 second, lower <code>argon2Memory</code> to 32 MiB and raise <code>argon2Iterations</code> to 4.
Estimate	30 minutes.

8. Summary

When	Items
Before the next deploy	1 (access-token TTL), 2 (Fly configuration verification)
Before real users	3 (lockout), 4 (audit log), 5 (wildcard escape), 6 (trigram index)
When there is time	7 (nonce CSP), 8 (CSRF binding), 9 (Argon2id parameters), 10 (session cap), 11 (boot logging)
Polish	12–17

9. Suggested schedule

A concrete plan for the next seven days:

Day	Work
Today	Item 2 (verify <code>fly.toml</code> , deploy). Fifteen minutes, and it is the gate for the deployment.
Day 1	Item 1 (shorten <code>JWT_ACCESS_TTL</code> to 2 minutes and update the documentation). Half a day at most.
Day 2–3	Item 4 (audit log). The item with the most future value; it pays for itself the first time someone asks "who changed this".
Day 4–5	Item 3 (account logout). The last of the "before real users" items.
Day 6–7	Items 5, 6, 11, 14, 16. The small ones, batched. Each is under two hours.

The remaining items — 7, 8, 9, 10, 12, 13, 15, 17 — can be done opportunistically when the surrounding code is being touched. That is how lists like this actually get finished: not by scheduling every item, but by picking them up when the opportunity is adjacent.

10. Changes since the previous roadmap

- **Items 1 and 2 from the previous list are done.** Trusted proxies and fail-closed HSTS/CSP defaults are in place, tested, and verified by the current test suite.
- **The QF1008 lint fixes are done.** Three redundant embedded-field selectors were simplified; `make lint` is clean.
- **A new item (17) was added.** Benchmarking the Argon2id parameters on Fly closes the loop on the parameter tuning that was done on the development machine. It is a measurement, not a code change.
- **Item numbering has shifted.** Use this document's numbering going forward. Cross-references to earlier roadmap versions will not match.